Seguridad de la Información y Gobierno de TI

Actividad formativa sobre buenas prácticas de seguridad en sistemas informáticos

Made with GAMMA

¿Qué es la Seguridad de la Información?

La seguridad de la información protege los sistemas y datos contra accesos no autorizados, uso indebido, revelación, alteración o destrucción.

En desarrollo de software, garantiza que el código, los repositorios y la información de usuarios permanezcan protegidos durante todo el ciclo de vida del proyecto.

Confidencialidad

Solo usuarios autorizados acceden a la información

Integridad

Los datos son precisos y consistentes

Disponibilidad

Los sistemas son accesibles cuando se necesitan

Made with GAMMA

Contexto: Incidente de Seguridad

1

Situación inicial

Aprendiz dejó su cuenta de sistema abierta sin cierre de sesión

2

Acción no autorizada

Tercero manipuló el contenido de un repositorio asociado a la cuenta

3

Consecuencia

Las acciones realizadas quedaron registradas bajo la identidad autenticada del usuario legítimo

Riesgo principal: Cuando una cuenta permanece abierta, cualquier acción realizada se atribuye al usuario autenticado, generando responsabilidad legal y técnica.

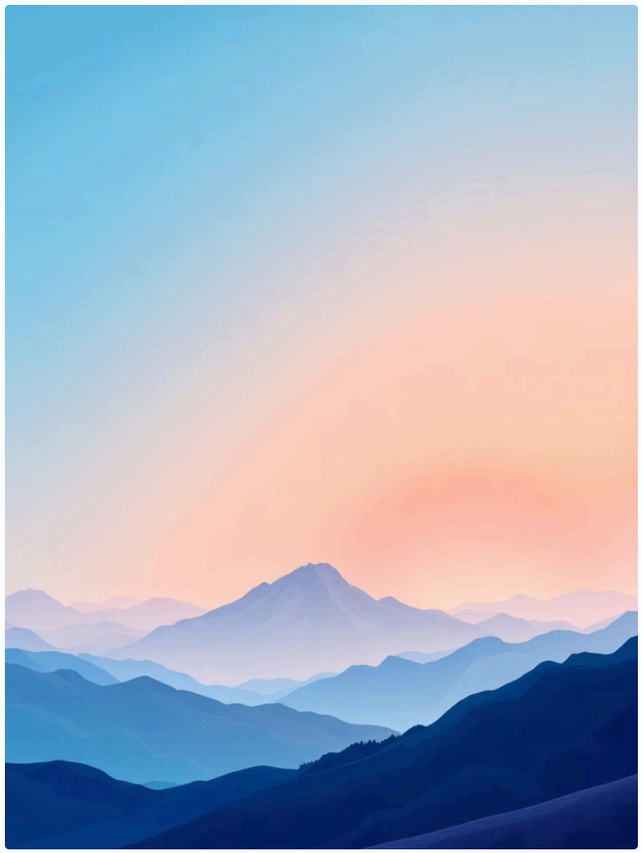
Made with GAMMA

ISO/IEC 27001: Estándar de Seguridad

ISO/IEC 27001 es el estándar internacional que especifica los requisitos para establecer, implementar, mantener y mejorar continuamente un Sistema de Gestión de Seguridad de la Información (SGSI).

Objetivo principal

Proteger la información sensible mediante gestión sistemática de riesgos y controles de seguridad apropiados.



01

Definir el alcance del SGSI

02

Realizar análisis de riesgos

03

Seleccionar controles de seguridad

04

Implementar y operar

05

Monitorear y revisar

Made with GAMMA

Sistema de Gestión de Seguridad de la Información (SGSI)

Un SGSI es un enfoque estructurado para gestionar la seguridad de la información de una organización mediante políticas, procedimientos y controles.

Planificar

Identificar riesgos y definir políticas

Implementar

Desplegar controles y procedimientos

Verificar

Realizar auditorías y revisiones

Mejorar

Actualizar controles continuamente

Made with GAMMA

Controles de Seguridad Relevantes

Control de accesos

Restringir el acceso a sistemas y datos solo a usuarios autorizados mediante permisos y roles definidos.

Autenticación

Verificar la identidad de usuarios mediante credenciales seguras como contraseñas robustas y autenticación multifactor.

Gestión de riesgos

Identificar, evaluar y mitigar amenazas potenciales mediante análisis periódicos y controles preventivos.

Auditoría y monitoreo

Registrar y revisar actividades de usuarios para detectar accesos sospechosos y garantizar cumplimiento.

Made with GAMMA

COBIT 5: Framework de Gobierno de TI

¿Qué es COBIT?

Control Objectives for Information and Related Technologies (COBIT) es un framework de gobernanza y gestión de TI desarrollado por ISACA.

Objetivo principal

Alinear las tecnologías de información con los objetivos del negocio mediante procesos estandarizados y métricas claras.

Alineación estratégica

Entrega de valor

Gestión de riesgos

Optimización de recursos

Made with GAMMA

Principios de Gobierno de TI según COBIT

Alineación estratégica

Integrar las inversiones y procesos de TI con los objetivos estratégicos de la organización para maximizar el valor del negocio.

Entrega de valor

Optimizar el desempeño de TI para cumplir con las expectativas de stakeholders mediante métricas claras y resultados medibles.

Gestión de riesgos

Establecer un equilibrio entre riesgos y beneficios mediante políticas claras, controles preventivos y planes de respuesta.

Optimización de recursos

Gestionar eficientemente los activos de TI, personal, infraestructura y presupuesto para obtener el máximo rendimiento.

Made with GAMMA

Buenas Prácticas de Seguridad para Desarrolladores

1

Cerrar sesiones correctamente

Nunca dejes tu cuenta abierta. Cierra sesión al terminar de trabajar, especialmente en equipos compartidos.

2

Implementar MFA

Habilita autenticación multifactor en todas tus cuentas para añadir una capa adicional de protección.

3

Contraseñas seguras

Utiliza contraseñas únicas, complejas y cambialas periódicamente. Considera usar un gestor de contraseñas.

4

Gestión de repositorios

Protege tus repositorios con permisos adecuados. No comparte credenciales ni claves de acceso.

5

Principio de mínimo privilegio

Concede solo los permisos necesarios para realizar tareas específicas. Evita privilegios excesivos.

Made with GAMMA

Conclusiones y Test Interactivo

Conclusiones clave

- La seguridad de la información protege confidencialidad, integridad y disponibilidad
- ISO/IEC 27001 proporciona el marco para gestionar riesgos de seguridad
- COBIT 5 alinea TI con objetivos estratégicos del negocio
- Cada usuario es responsable de aplicar buenas prácticas

Test: ¿Qué harías en estas situaciones?

Pregunta 1

¿Qué debes hacer si necesitas dejar tu computadora por un momento?

A) Dejarla abierta si es breve
B) Bloquear la pantalla
C) Cerrar sesión siempre

Pregunta 2

¿Cuál es el propósito de la autenticación multifactor (MFA)?

A) Facilitar el acceso
B) Añadir capas de seguridad
C) Recordar contraseñas

Pregunta 3

¿Qué significa el principio de mínimo privilegio?

A) Dar todos los permisos
B) Conceder solo lo necesario
C) Compartir credenciales

Made with GAMMA